Week 8

Active Directory Security Audit

Screenshots and proofs from my home lab

Logs, lockout policy, privileged groups, GPO, audit script

Machine names, account names and the domain name are redacted.

Day 1 - Reading logon events

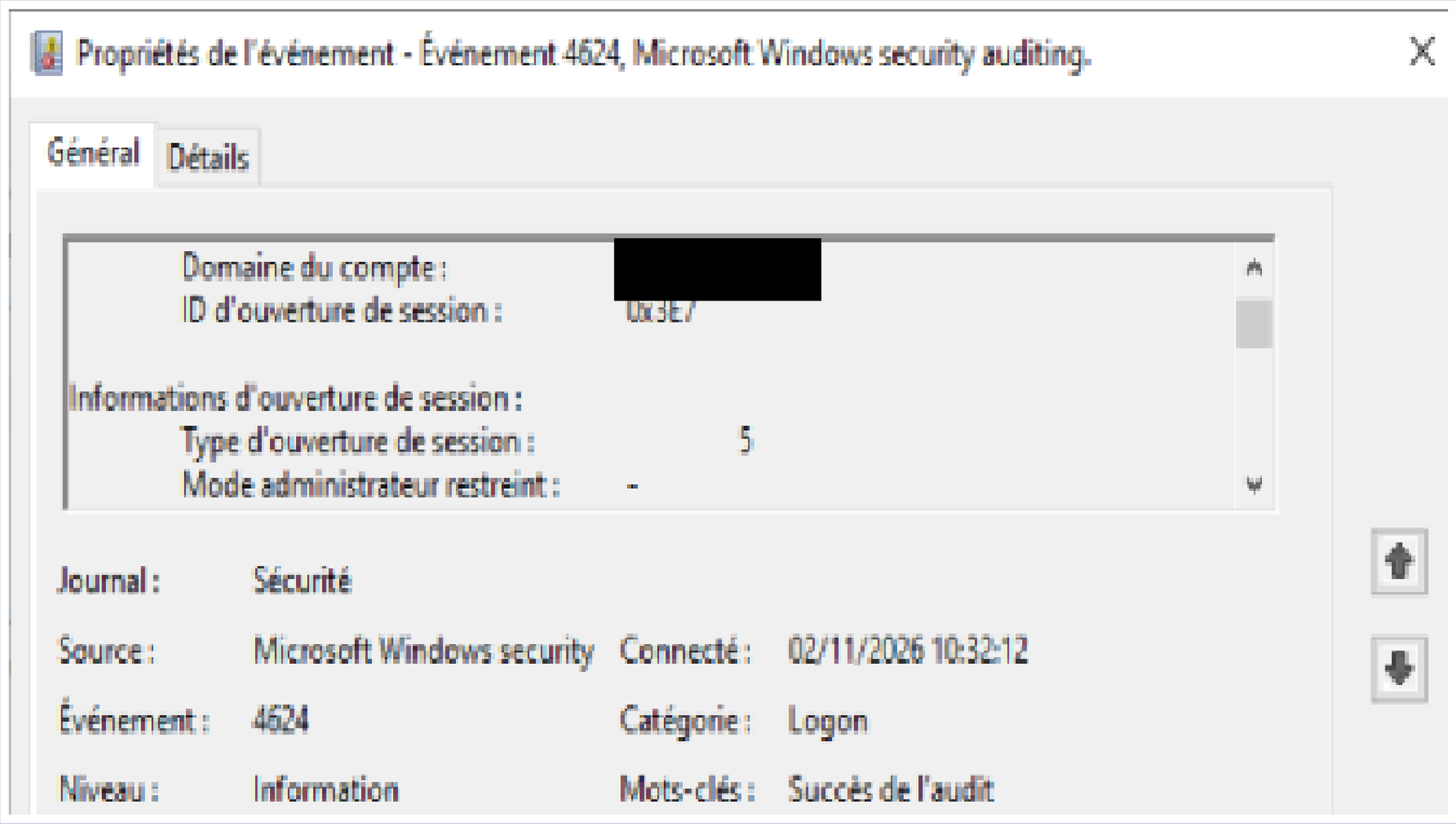
Successful logons (Event 4624) listed with Get-WinEvent

```
PS C:\Windows\system32> Get-WinEvent -FilterHashtable @{LogName='Security'; Id=4624} -MaxE
vent 5 | Select-Object TimeCreated, Id

TimeCreated                      Id
-----------                      --
02/11/2026 10:32:12 4624
02/11/2026 10:31:44 4624
02/11/2026 10:31:19 4624
02/11/2026 10:28:22 4624
02/11/2026 10:25:15 4624
```

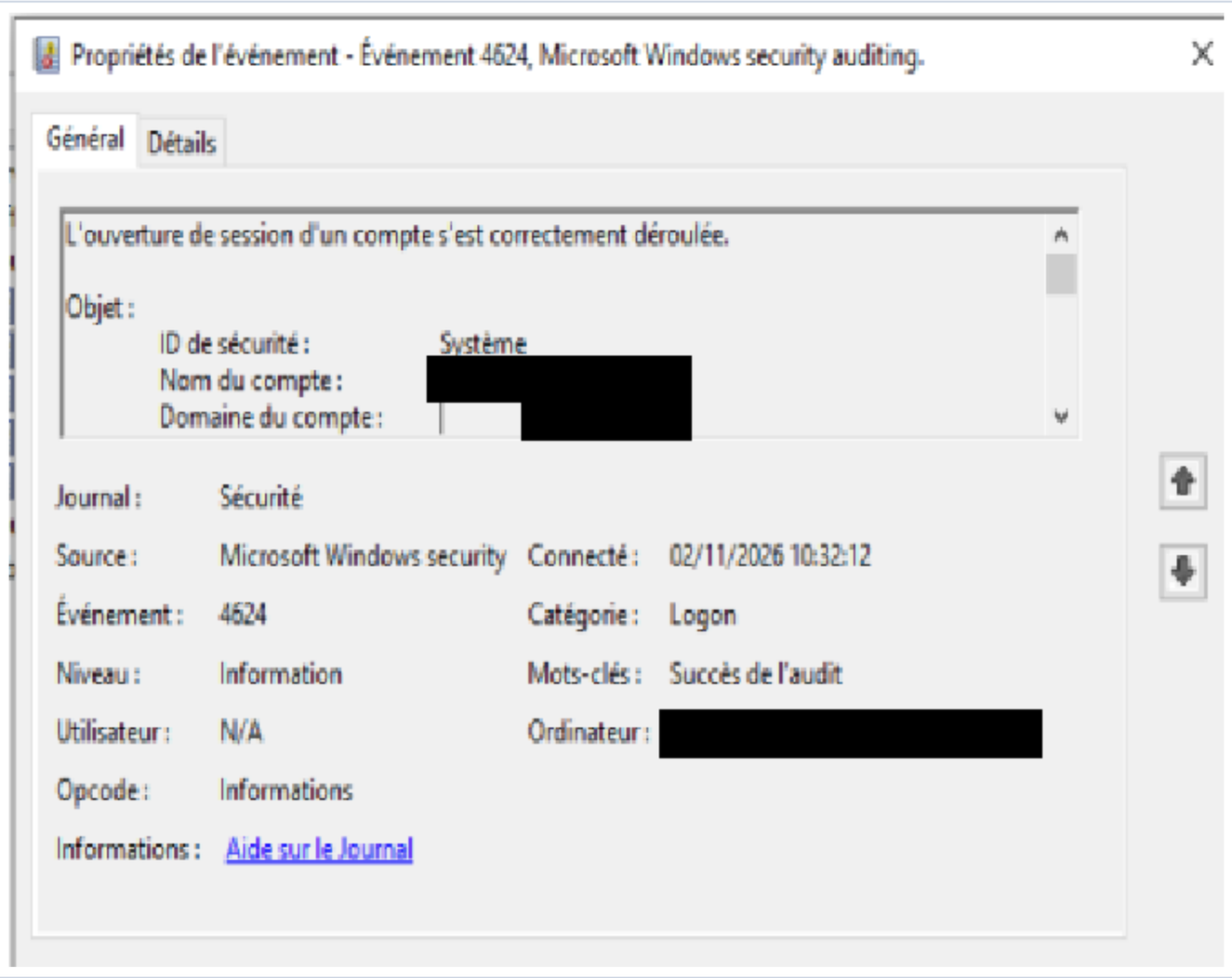
Day 1 - Reading logon events

Logon Type 5: a service, not a person at a keyboard



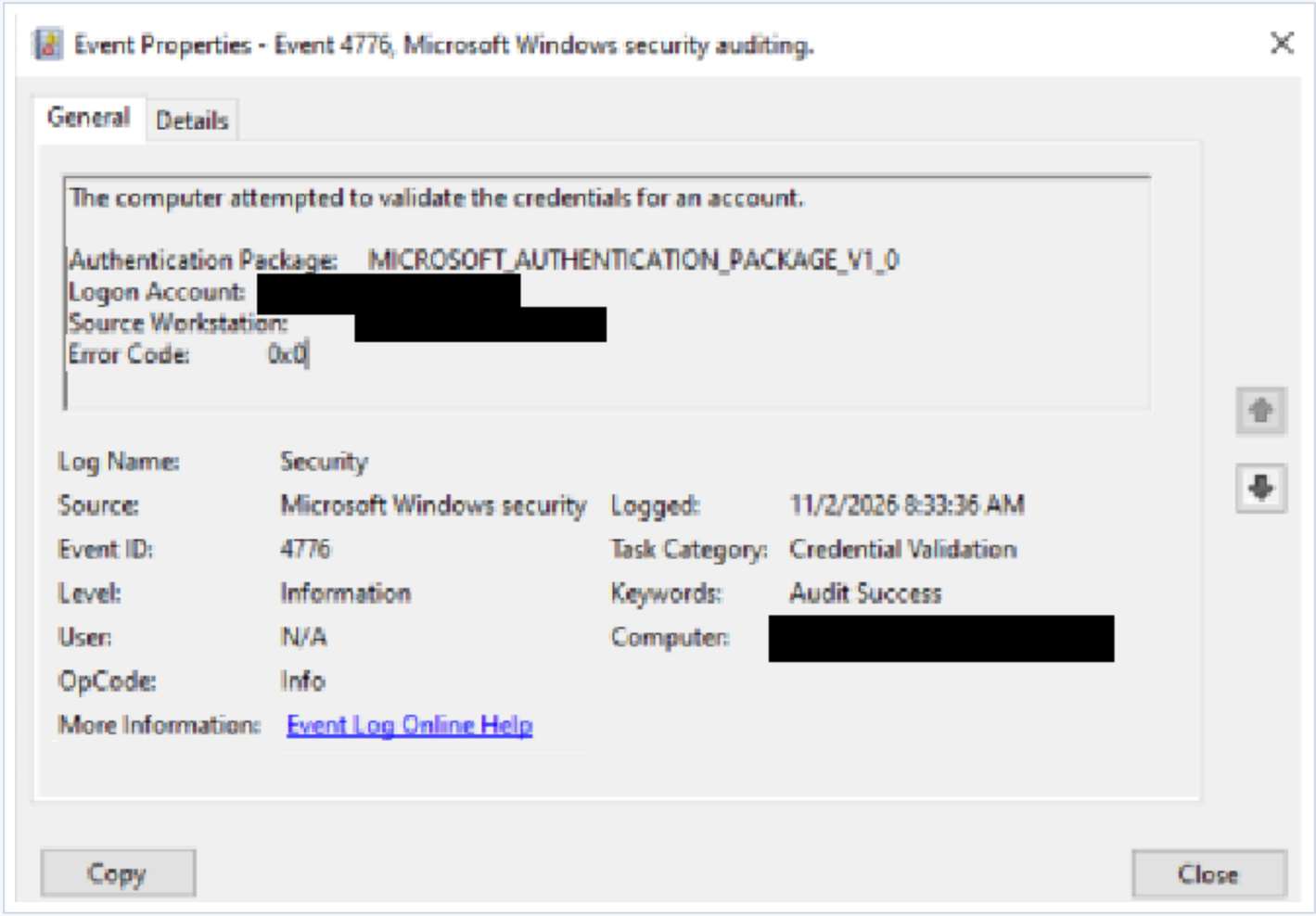
Day 1 - Reading logon events

Account name ending with "$": a machine account



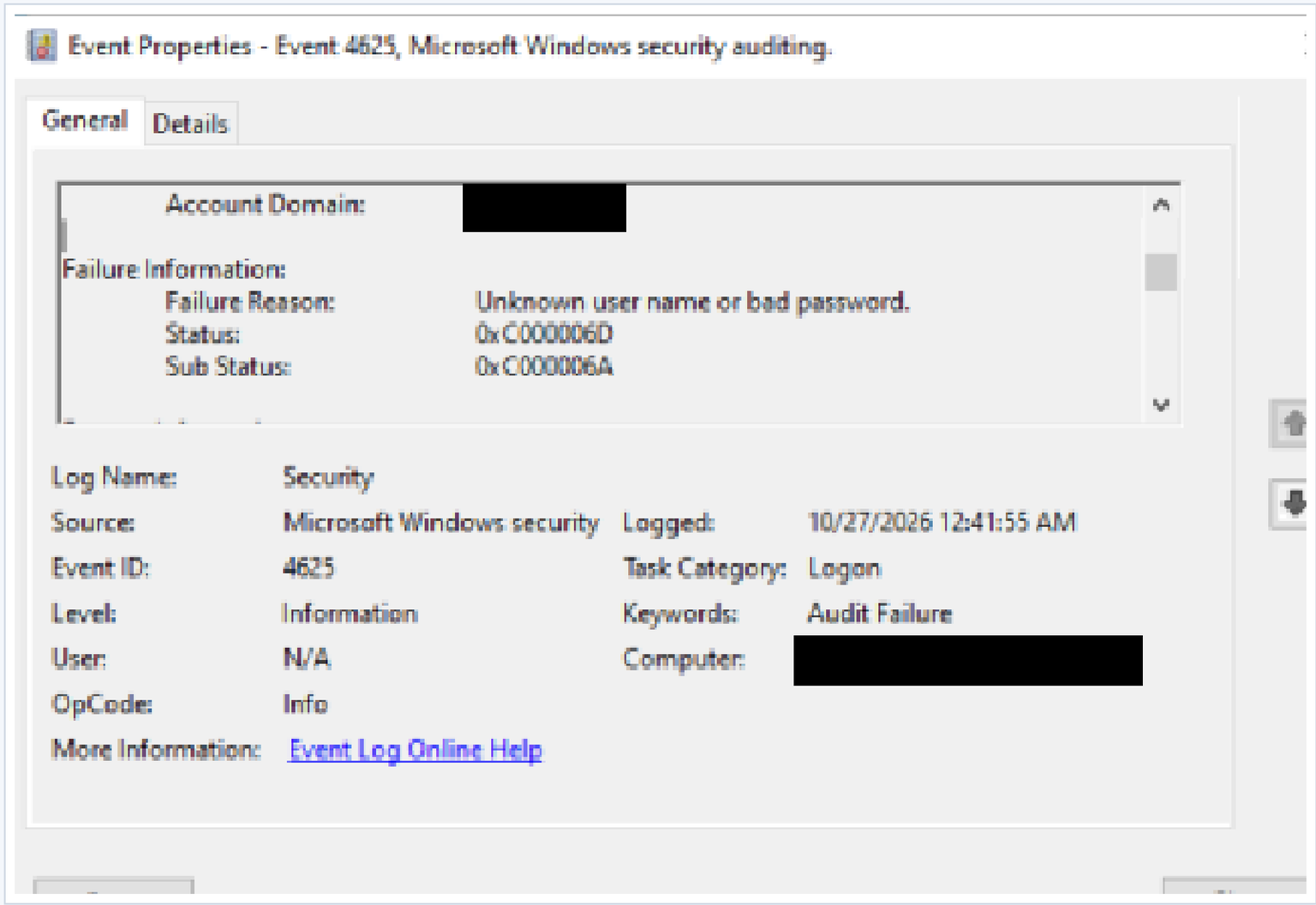
Day 1 - Reading logon events

The domain controller logged a credential validation (4776, Error Code 0x0) from another machine



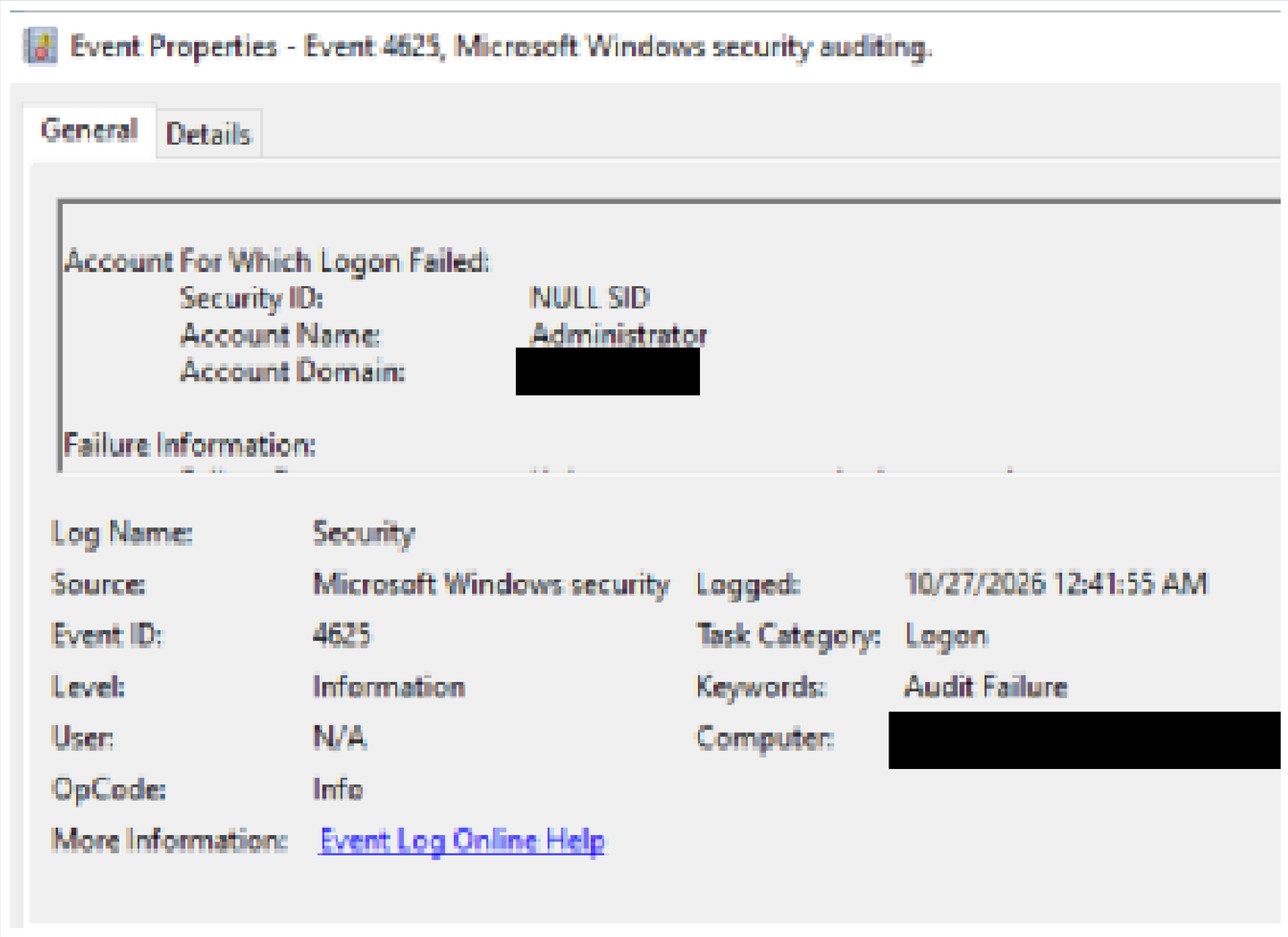
Day 1 - Reading logon events

Failed logon (4625): Unknown user name or bad password, Sub Status 0xC000006A



Day 1 - Reading logon events

Account For Which Logon Failed: read this block, not the Subject block



Day 2 - Password policy and lockout

Before: LockoutThreshold = 0, accounts are never locked

```
PS C:\Users\Administrator> Get-ADDefaultDomainPasswordPolicy


ComplexityEnabled           : True
DistinguishedName           : [redacted]
LockoutDuration             : 00:30:00
LockoutObservationWindow    : 00:30:00
LockoutThreshold            : 0
MaxPasswordAge              : 42.00:00:00
MinPasswordAge              : 1.00:00:00
MinPasswordLength           : 7
objectClass                 : {domainDNS}
objectGuid                  : [redacted]
PasswordHistoryCount        : 24
ReversibleEncryptionEnabled : False
```

Day 2 - Password policy and lockout

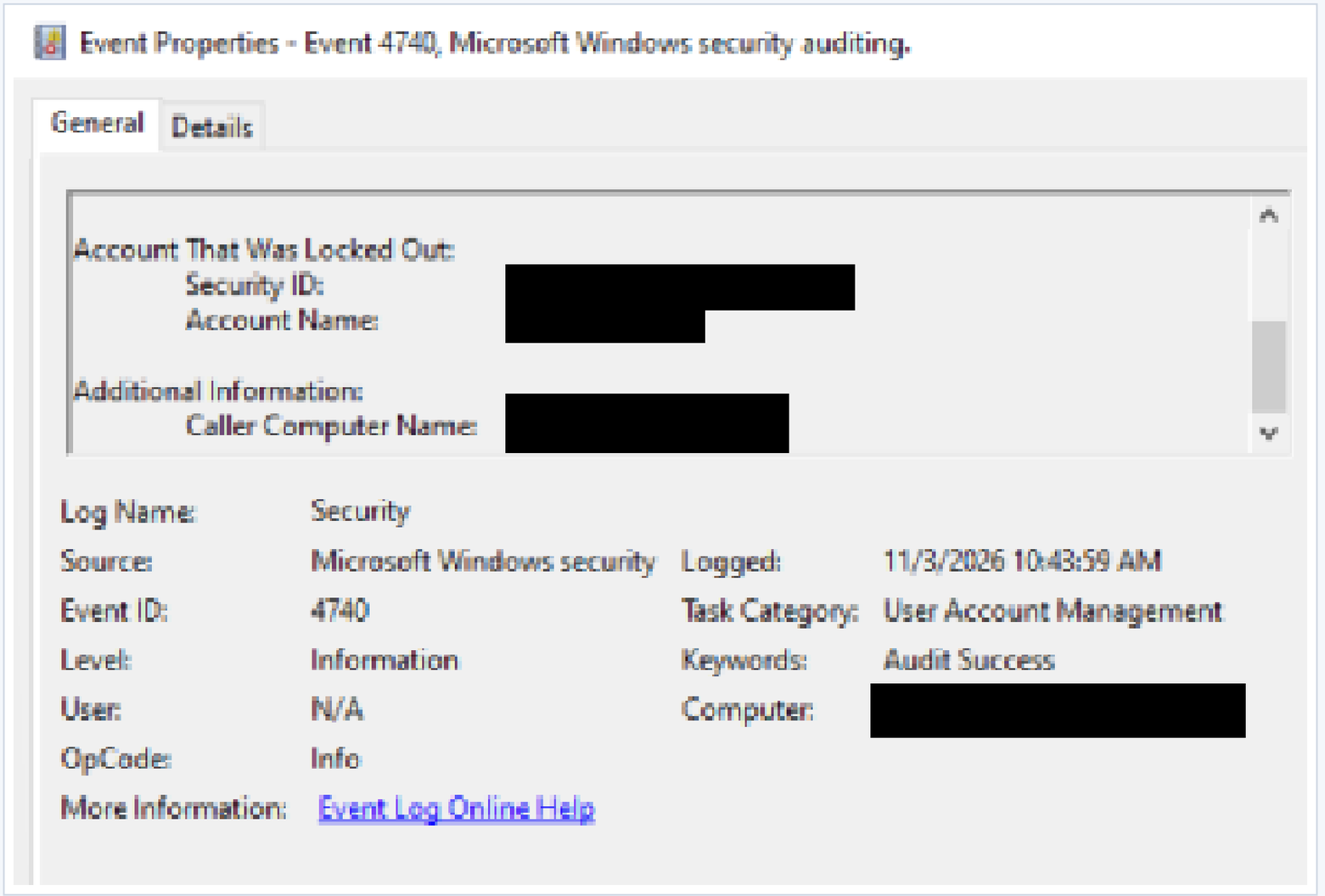
Fix: lockout threshold set to 5 attempts, 30 minutes

```
PS C:\Users\Administrator> Set-ADDefaultDomainPasswordPolicy -Identity [redacted]
[redacted] -LockoutThreshold 5
PS C:\Users\Administrator> Get-ADDefaultDomainPasswordPolicy | Select-Object
 LockoutThreshold, LockoutDuration, LockoutObservationWindow

LockoutThreshold LockoutDuration LockoutObservationWindow
---------------- ---------------- ------------------------
               5 00:30:00         00:30:00
```

Day 2 - Password policy and lockout

Event 4740: the locked account and the machine the bad passwords came from



Day 3 - Privileged groups and GPO

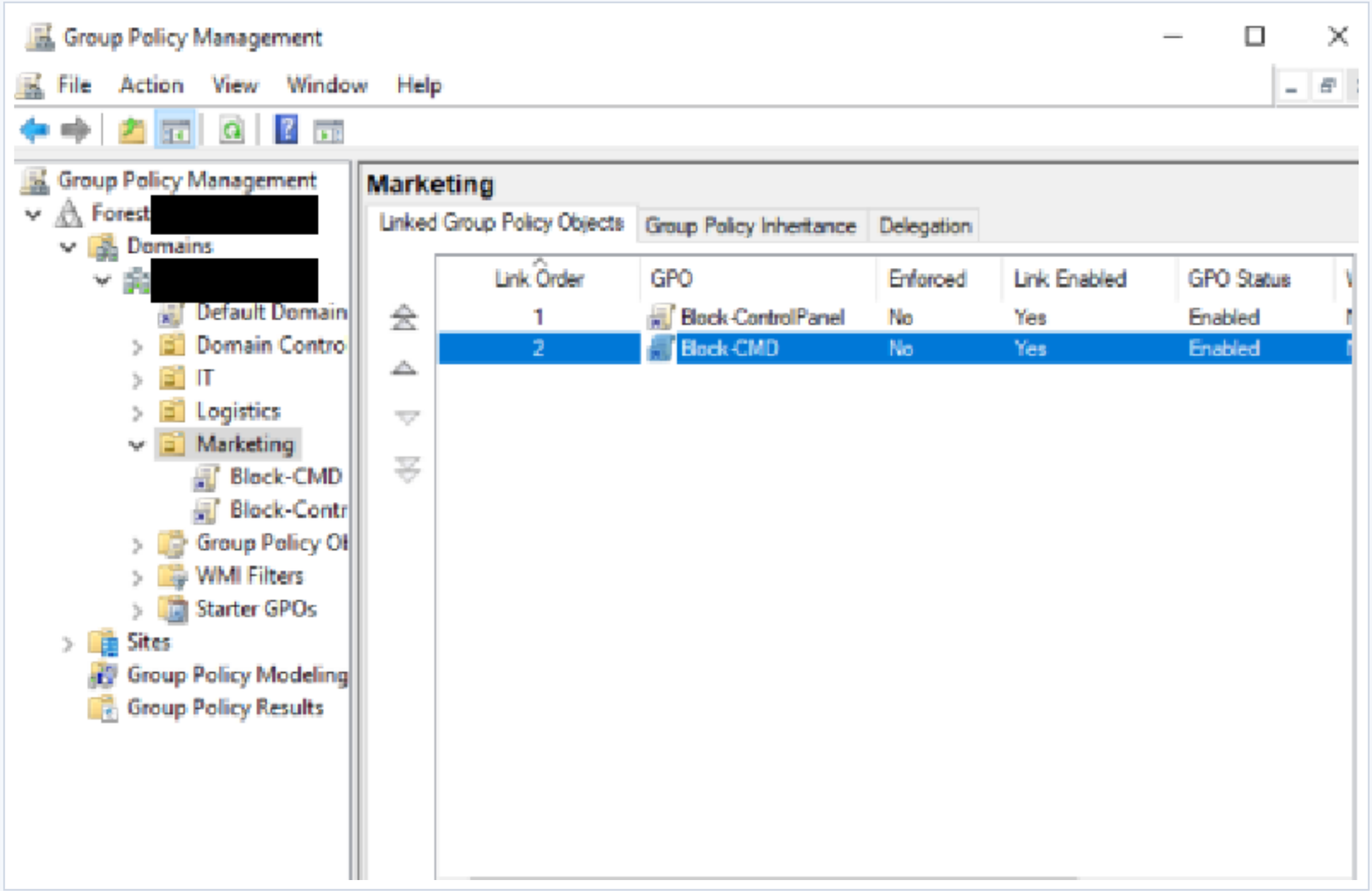
Domain Admins has a single member: the built-in Administrator

```
PS C:\Users\Administrator> Get-ADGroupMember -Identity "Domain Admins" | Sel
ect-Object Name, SamAccountName

Name          SamAccountName
----          --------------
Administrator Administrator
```

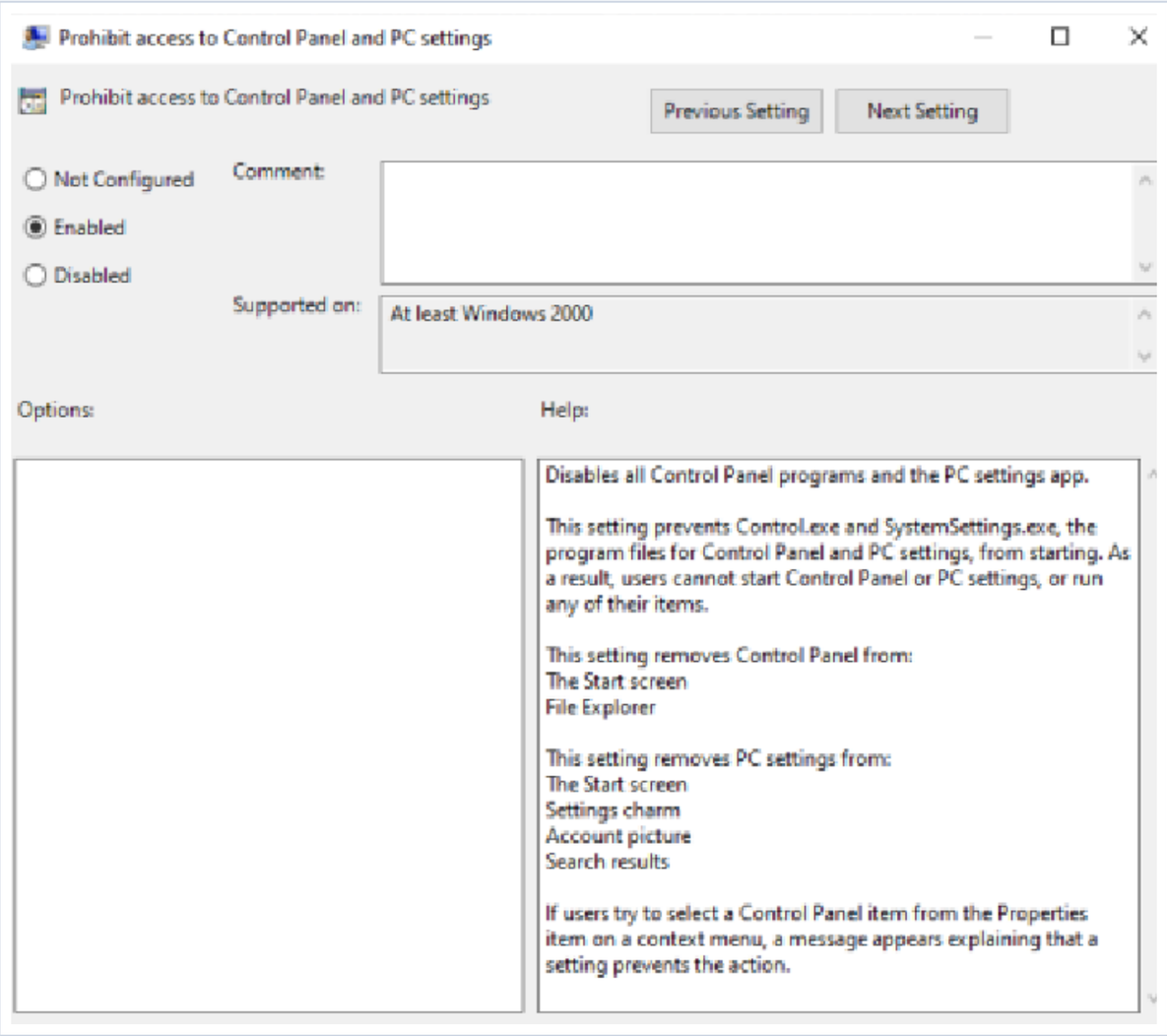
Day 3 - Privileged groups and GPO

Two GPOs linked to the Marketing OU



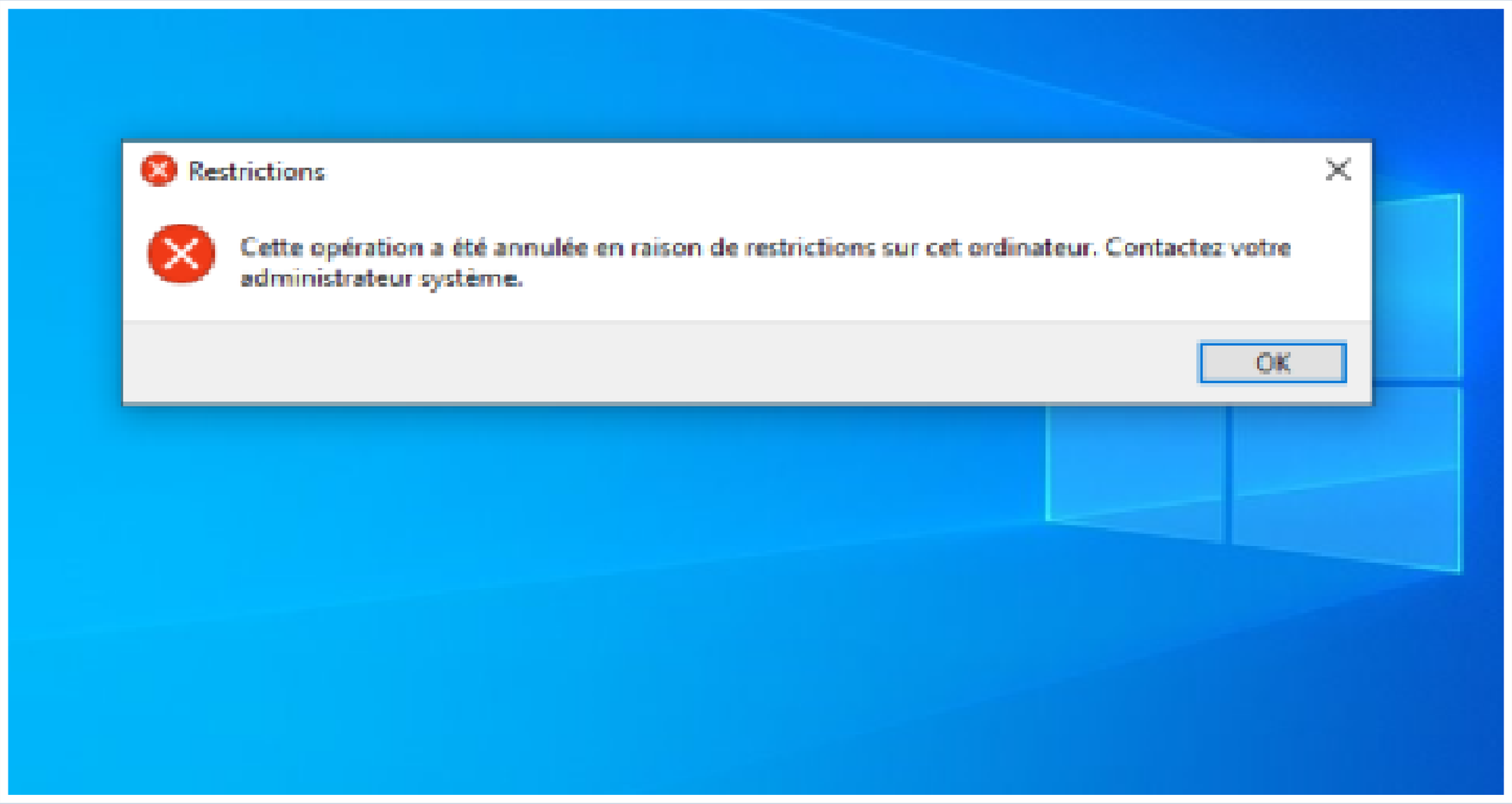
Day 3 - Privileged groups and GPO

Control Panel blocked: policy set to Enabled



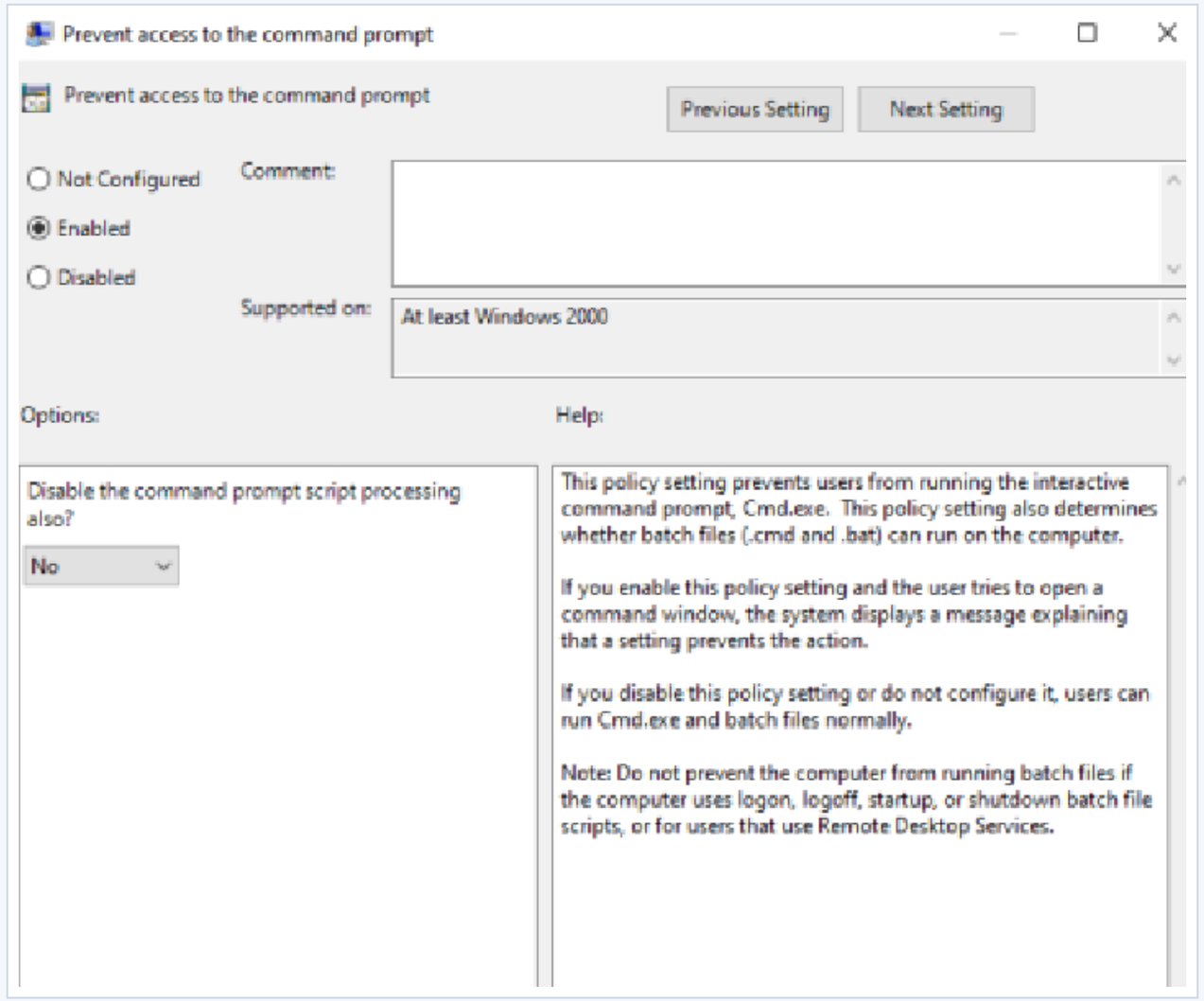
Day 3 - Privileged groups and GPO

Result on the client after gpupdate /force: access cancelled by restrictions



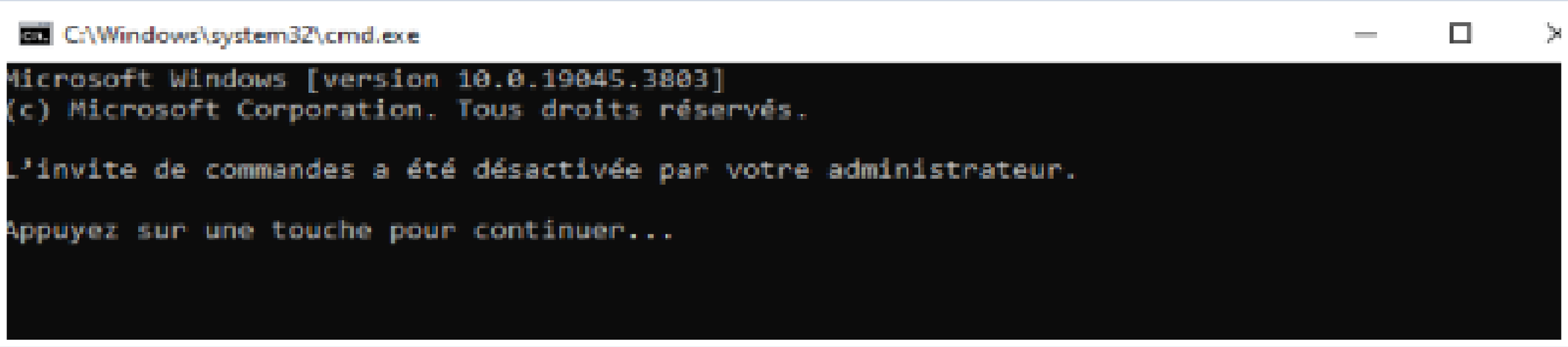
Day 3 - Privileged groups and GPO

Command prompt blocked: policy set to Enabled (scripts still allowed)



Day 3 - Privileged groups and GPO

Result on the client: command prompt disabled by the administrator



Day 4 - Mini-project: audit-ad.ps1

The audit script: password policy, Domain Admins, disabled accounts

```
PS C:\Users\Administrator> C:\audit-ad.ps1
=== 1. Password policy ===


MinPasswordLength : 7
ComplexityEnabled : True
MaxPasswordAge    : 42.00:00:00
LockoutThreshold  : 5
LockoutDuration   : 00:30:00

=== 2. Domain Admins members ===
Name              : Administrator
SamAccountName    : Administrator

=== 3a. Disabled accounts ===
Name              : krbtgt
SamAccountName    : krbtgt

Name              : Guest
SamAccountName    : Guest
```

Day 4 - Mini-project: audit-ad.ps1

No locked-out accounts, and one failed logon (4625) in the last 7 days

```
=== 3a. Disabled accounts ===
Name              : krbtgt
SamAccountName    : krbtgt

Name              : Guest
SamAccountName    : Guest

=== 3b. Locked-out accounts ===
=== 4. Failed logons (last 7 days) ===
TimeCreated : 11/4/2026 6:50:43 AM
Id          : 4625
```

What I learned

- A domain controller logs authentication for the whole domain.
- Read the right block of an event: Subject vs. the affected account.
- A default setting is not always a secure setting.
- Auditing is how you find out.

Next: Month 3 - Blue Team and SOC